PUBLIC KEY INFRASTRUCTURE

S05: Giao thức TLS 1.3 & Kiến trúc mTLS Zero Trust

Nguyen An Khuong, *CSE-HCMUT*
ORCID: 0000-0002-9910-6387 · Email: nakhuong@hcmut.edu.vn

Ho Chi Minh City University of Technology (HCMUT), VNU-HCM
Faculty of Computer Science and Engineering
Teaching Assistant: Mr. Nguyen Huu Hoang Huy (LinkedIn Profile)

Session 5 of 9 · ATHK 512 (KMA CHAT4P, HK261)
Class: Sat 31/10/2026 · 13h30–18h30
Standards: IETF RFC 8446 (TLS 1.3), SPIFFE/SPIRE, Envoy Proxy

PUBLIC KEY INFRASTRUCTURE
S05: Giao thức TLS 1.3 & Kiến trúc mTLS Zero Trust

1. Tổng quan & Lộ trình Buổi S05

Lộ Trình Học Phần (Buổi 5/9)

S01: Architecture, Trust & Threat Models	S02: X.509, ASN.1 & Path Validation	S03: CA Lifecycle & ACME Protocol
S04: Revocation (CRL/OCSP) & Hardware HSM	**S05: TLS 1.3 & mTLS Zero Trust Gateway**	S06: Certificate Transparency (CT) Logs & Merkle Tree
S07: PQC Migration NIST FIPS 203/204	S08: Enterprise AD CS Attack & Defense	S09: Capstone Defense & Audit Synthesis

Buổi học đưa chứng chỉ số vào bảo vệ kênh truyền thực tế: phân tích bước nhảy vọt của giao thức TLS 1.3 và kiến trúc xác thực hai chiều mTLS trong mạng lưới Microservices Zero Trust.



S5-1 · Lộ Trình Học Phần (Buổi 5/9)

[2 phút | 13h30–13h32] Giới thiệu Buổi 5: Giao thức bắt tay TLS 1.3 và mô hình an ninh Zero Trust với mTLS Gateway.

Chuẩn Đầu Ra Buổi Học S05 (Learning Objectives)

Sau buổi h

1. **Phân tích** chi tiết quy trình bắt tay 1-RTT của giao thức TLS 1.3 (RFC 8446).
2. **Chứng minh** tính chất bí mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy – PFS).
3. **Thiết kế** kiến trúc xác thực hai chiều mTLS bảo vệ kết nối giữa các microservices.
4. **Triển khai** định danh tài nguyên động dạng SPIFFE ID và cấu hình Reverse Proxy Envoy/Nginx.

Triết Lý Kiến Trúc Zero Trust. ”Không bao giờ tin tưởng, luôn luôn xác thực” (Never Trust, Always Verify). Mạng nội bộ không an toàn hơn Internet. Mọi kết nối giữa các microservices bắt buộc phải có chứng chỉ số mTLS hợp lệ!


Chuẩn Đầu Ra Buổi Học S05 (Learning Objectives)
Sau buổi học S05, học viên làm chủ các năng lực:
1. Phân tích chi tiết quy trình bắt tay 1-RTT của giao thức TLS 1.3 (RFC 8446).
2. Chứng minh tính chất bí mật chuyển tiếp hoàn hảo (Perfect Forward Secrecy – PFS).
3. Thiết kế kiến trúc xác thực hai chiều mTLS bảo vệ kết nối giữa các microservices.
4. Triển khai định danh tài nguyên động dạng SPIFFE ID và cấu hình Reverse Proxy Envoy/Nginx.
Triết Lý Kiến Trúc Zero Trust. "Không bao giờ tin tưởng, luôn luôn xác thực" (Never Trust, Always Verify). Mạng nội bộ không an toàn hơn Internet. Mọi kết nối giữa các microservices bắt buộc phải có chứng chỉ số mTLS hợp lệ!

S5-2 · Chuẩn Đầu Ra Buổi Học S05 (Learning Objectives)

[3 phút | 13h32–13h35] Nhấn mạnh sự sụp đổ của chu vi mạng (Perimeter Defense) và vai trò trung tâm của mTLS trong Zero Trust.

2. Giao thức TLS 1.3 (RFC 8446)

Bước Nhảy Vọt Của Giao Thức TLS 1.3 So Với TLS 1.2

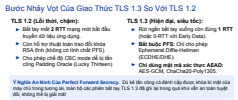
TLS 1.2 (Lỗi thời, chậm):

- Bắt tay mất **2 RTT** mạng mới bắt đầu truyền dữ liệu ứng dụng.
- Còn hỗ trợ thuật toán trao đổi khóa RSA tĩnh (không có tính chất PFS).
- Cho phép chế độ CBC mode dễ bị tấn công Padding Oracle (Lucky Thirteen).

TLS 1.3 (Hiện đại, siêu tốc):

- Rút ngắn bắt tay xuống còn đúng **1 RTT** (hoặc 0-RTT với Early Data).
- **Bắt buộc PFS:** Chỉ cho phép Ephemeral Diffie-Hellman (ECDHE/DHE).
- **Chỉ dùng mật mã xác thực AEAD:** AES-GCM, ChaCha20-Poly1305.

Ý Nghĩa An Ninh Của Perfect Forward Secrecy. Dù kẻ tấn công có đánh cắp được khóa bí mật của máy chủ trong tương lai, toàn bộ các phiên bắt tay TLS 1.3 đã ghi lại trong quá khứ vẫn an toàn tuyệt đối, không thể bị giải mã!


Bước Nhảy Vọt Của Giao Thức TLS 1.3 So Với TLS 1.2

TLS 1.2 (Lỗi thời, chậm):
- Bắt tay mất 2 RTT mạng mới bắt đầu truyền dữ liệu ứng dụng.
- Còn hỗ trợ thuật toán trao đổi khóa RSA tĩnh (không có tính chất PFS).
- Cho phép chế độ CBC mode dễ bị tấn công Padding Oracle (Lucky Thirteen).

TLS 1.3 (Hiện đại, siêu tốc):
- Rút ngắn bắt tay xuống còn đúng 1 RTT (hoặc 0-RTT với Early Data).
- Bắt buộc PFS: Chỉ cho phép Ephemeral Diffie-Hellman (ECDHE/DHE).
- Chỉ dùng mật mã xác thực AEAD: AES-GCM, ChaCha20-Poly1305.

Ý Nghĩa An Ninh Của Perfect Forward Secrecy. Dù kẻ tấn công có đánh cắp được khóa bí mật của máy chủ trong tương lai, toàn bộ các phiên bắt tay TLS 1.3 đã ghi lại trong quá khứ vẫn an toàn tuyệt đối, không thể bị giải mã!

S5-3 · Bước Nhảy Vọt Của Giao Thức TLS 1.3 So Với TLS 1.2

[3 phút | 13h35–13h38] Phân tích lý do TLS 1.3 khai tử trao đổi khóa RSA: Bảo đảm tính chất PFS bắt buộc.

Sơ Đồ Bắt Tay 1-RTT Trong TLS 1.3



Điểm cải tiến then chốt:
- Client gửi ngay khóa trao đổi g^a trong gói tin đầu tiên (Key Share).
- Toàn bộ thông tin chứng chỉ máy chủ được mã hóa bằng khóa phiên, bảo vệ quyền riêng tư trước kẻ nghe lén trên đường truyền!



S5-4 · Sơ Đồ Bắt Tay 1-RTT Trong TLS 1.3

[3 phút | 13h38–13h41] Mổ xẻ chi tiết gói tin bắt tay TLS 1.3: Mã hóa chứng chỉ ngay từ gói tin phản hồi của máy chủ.

3. Kiến trúc Xác thực Hai Chiều mTLS & SPIFFE/SPIRE

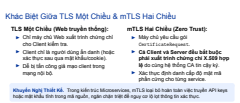
Khác Biệt Giữa TLS Một Chiều & mTLS Hai Chiều

TLS Một C

- Chỉ máy chủ Web xuất trình chứng chỉ cho Client kiểm tra.
- Client chỉ là người dùng ẩn danh (hoặc xác thực sau qua mật khẩu/cookie).
- Dễ bị tấn công giả mạo client trong mạng nội bộ.

- Máy chủ yêu cầu gói `CertificateRequest`.
- **Cả Client và Server đều bắt buộc phải xuất trình chứng chỉ X.509 hợp lệ** do cùng hệ thống CA tin cậy ký.
- Xác thực định danh cấp độ mật mã phần cứng cho từng service.

Khuyến Nghị Thiết Kế. Trong kiến trúc Microservices, mTLS loại bỏ hoàn toàn việc truyền API keys hoặc mật khẩu tĩnh trong mã nguồn, ngăn chặn triệt để nguy cơ lộ lọt thông tin xác thực.


Khác Biệt Giữa TLS Một Chiều & mTLS Hai Chiều

TLS Một Chiều (Web truyền thống):
- Chỉ máy chủ Web xuất trình chứng chỉ cho Client kiểm tra.
- Client chỉ là người dùng ẩn danh (hoặc xác thực sau qua mật khẩu/cookie).
- Dễ bị tấn công giả mạo client trong mạng nội bộ.

mTLS Hai Chiều (Zero Trust):
- Máy chủ yêu cầu gửi CertificateRequest.
- Cả Client và Server đều bắt buộc phải xuất trình chứng chỉ X.509 hợp lệ do cùng hệ thống CA tin cậy ký.
- Xác thực định danh cấp độ mật mã phần cứng cho từng service.

Khuyến Nghị Thiết Kế. Trong kiến trúc Microservices, mTLS loại bỏ hoàn toàn việc truyền API keys hoặc mật khẩu tĩnh trong mã nguồn, ngăn chặn triệt để nguy cơ lộ lọt thông tin xác thực.

S5-5 · Khác Biệt Giữa TLS Một Chiều & mTLS Hai Chiều

[3 phút | 13h41–13h44] Phân tích vai trò của mTLS trong việc bảo vệ các kết nối dịch vụ tài chính, ngân hàng và đám mây.

Chuẩn Định Danh SPIFFE & Nền Tảng SPIRE

Beyond · Why It Matters. Làm thế nào để cấp phát chứng chỉ số cho hàng nghìn container tự động sinh ra và tự hủy trong vài phút mà không lưu private key lên ổ cứng?

- **SPIFFE ID:** Chuỗi định danh chuẩn hóa dạng URI trong SAN:

```
spiffe://kma.edu.vn/ns/prod/sa/payment-service
```

- **SVID (SPIFFE Verifiable Identity Document):** Chứng chỉ số X.509 ngắn hạn (thời hạn 1 giờ) cấp trực tiếp vào bộ nhớ RAM của Pod.
- **SPIRE Agent:** Lắng nghe API Kernel Linux (cgroups, namespaces) để tự động chứng thực pod và xoay vòng chứng chỉ định kỳ.



S5-6 · Chuẩn Định Danh SPIFFE & Nền Tảng SPIRE

[3 phút | 13h44–13h47] Giới thiệu chuẩn SPIFFE/SPIRE: Tiêu chuẩn vàng của điện toán đám mây Cloud Native.

Bài Tập Tự Kiểm Tra Buổi S05

Câu Hỏi Thẩm Định Năng Lực.

1. **Câu 1:** Một kỹ sư cấu hình Nginx làm mTLS Gateway nhưng chỉ kiểm tra chứng chỉ client hợp lệ mà quên kiểm tra trường SAN/Subject. Rủi ro là gì?
   Giải đáp: Bất kỳ ai sở hữu một chứng chỉ hợp lệ do cùng CA cấp (ví dụ tài khoản thực tập sinh) đều có thể kết nối thành công và mạo danh dịch vụ thanh toán nhạy cảm!
2. **Câu 2:** Vì sao chế độ 0-RTT trong TLS 1.3 lại tiềm ẩn nguy cơ tấn công phát lại (Replay Attack)?
   Giải đáp: Dữ liệu gửi trong 0-RTT Early Data không được bảo vệ chống phát lại. Kẻ tấn công có thể bắt gói tin này và gửi lại nhiều lần để lặp lại một lệnh thanh toán ngân hàng.

Bài Tập Tự Kiểm Tra Buổi S05
Câu Hỏi Thẩm Định Năng Lực.
1. Câu 1: Một kỹ sư cấu hình Nginx làm mTLS Gateway nhưng chỉ kiểm tra chứng chỉ client hợp lệ mà quên kiểm tra trường SAN/Subject. Rủi ro là gì?
Giải đáp: Bất kỳ ai sở hữu một chứng chỉ hợp lệ do cùng CA cấp (ví dụ tài khoản thực tập sinh) đều có thể kết nối thành công và mạo danh dịch vụ thanh toán nhạy cảm!
2. Câu 2: Vì sao chế độ 0-RTT trong TLS 1.3 lại tiềm ẩn nguy cơ tấn công phát lại (Replay Attack)?
Giải đáp: Dữ liệu gửi trong 0-RTT Early Data không được bảo vệ chống phát lại. Kẻ tấn công có thể bắt gói tin này và gửi lại nhiều lần để lặp lại một lệnh thanh toán ngân hàng.

S5-7 · Bài Tập Tự Kiểm Tra Buổi S05

[2 phút | 13h47–13h50] Tổng kết kiến thức Buổi 5 và hướng dẫn thực hành Lab 4.